

Engineering Governance für verlässliche Softwareentscheidungen

Whitepaper für die Geschäftsführung

Ausgabe 1.0

9. September 2026

Projekt devsecops-governance-framework

Das vorliegende Framework verbindet freigegebene Vorgaben mit wiederholbaren technischen Prüfungen und nachvollziehbaren Ergebnissen. Damit schafft es eine gemeinsame Grundlage für Entscheidungen über Softwarelieferungen. Dieses Whitepaper erläutert den geschäftlichen Nutzen, den belegten Entwicklungsstand und einen begrenzten Einführungsweg für die Geschäftsführung.

Die Empfehlung lautet, einen kontrollierten Testbetrieb mit ein bis zwei geeigneten Anwendungen vorzubereiten. Die technische Referenzimplementierung und die Betriebsanleitungen sind vorhanden. Ob sie im Alltag Aufwand verringern und Entscheidungen beschleunigen, muss der Testbetrieb erst zeigen. Eine belastbare Aussage über Einsparungen, unternehmensweite Betriebsreife oder vollständige Compliance lässt sich aus dem aktuellen Stand nicht ableiten. [1, 5, 8]

Für den Einstieg melden die Prüfungen ihre Ergebnisse, ohne Lieferungen allein wegen eines fachlichen Befunds automatisch zu stoppen. Verantwortliche Personen beurteilen Risiken und Ausnahmen weiterhin selbst. Ein späterer verbindlicher Einsatz benötigt aktuelle Nachweise und eine gesonderte Freigabe. [3, 5]

Die Geschäftsführung entscheidet zunächst über Umfang, Zuständigkeiten und verfügbare Kapazität für die Erprobung. Die Ausweitung folgt erst, wenn der Pilot zuverlässige Ergebnisse, einen tragfähigen Betrieb und einen erkennbaren Nutzen belegt. Vorgeschlagene Dauer und Kennzahlen in diesem Dokument sind Planungsgrößen, keine bereits erteilten Zusagen.

Leseführung: Die folgenden Seiten behandeln Nutzen, Funktionsweise, Aussagekraft der Nachweise, belegten Stand und Einführung. Quellen und Begriffe stehen am Ende. Grundlage ist der Repository-Stand vom 9. September 2026, Commit 6893577. Spätere Änderungen sind nicht Bestandteil dieser Ausgabe.

Geschäftlicher Nutzen und seine Messung

In einer verteilten Softwareorganisation müssen Verantwortliche regelmäßig klären, welche Vorgaben gelten, welche Nachweise vorliegen und welche Abweichungen offen sind. Wenn Teams diese Informationen unterschiedlich aufbereiten, entstehen Rückfragen und manuelle Zusammenstellungen. Das Framework adressiert dieses Problem mit gemeinsamen Nachweisformaten und wiederverwendbaren Prüfregelein. Diese Problemstellung beschreibt die Zielsetzung des Projekts, keine bereits gemessene Ausgangslage eines Unternehmens. [1, 4]

Der erwartete Nutzen liegt vor allem in einer nachvollziehbaren Entscheidungsgrundlage. Ein Ergebnis verweist auf die geprüfte Anwendung, ihren Versionsstand und den verwendeten Regelsatz. Die Herkunft einer Aussage lässt sich dadurch gezielter untersuchen. Gemeinsame Regeln können außerdem mehrfach gepflegte Prüflöge reduzieren. Ob die Gesamtarbeit tatsächlich sinkt, hängt von der Qualität der Eingangsdaten und vom zusätzlichen Betriebsaufwand ab.

Für die Führung wird sichtbar, wo Nachweise fehlen oder veralten und welche offenen Punkte eine Entscheidung brauchen. Die Plattform liefert jedoch keine automatische Priorisierung nach Geschäftsauswirkung. Dafür bleiben Produktverantwortliche, Security und Governance zuständig. Der Nutzen entsteht erst, wenn jemand Befunde bewertet und Maßnahmen verfolgt. [5, 9]

Im Pilot sollten dieselben ausgewählten Entscheidungen vor und nach der Einführung beobachtet werden. Ein kleiner Pilot liefert eine erste Einschätzung, aber keinen statistisch belastbaren Nachweis langfristiger Einsparungen. Es gibt derzeit keine belegte Rendite, Kostensenkung oder Verkürzung von Freigabezeiten.

Für die erste Auswertung genügt eine einfache Erfassung der tatsächlich aufgewendeten Zeit und der aufgetretenen Rückfragen. Wichtig ist ein vergleichbarer Umfang: Unterschiedlich große Releases oder wechselnde Prüfvorgaben würden den Vergleich verzerren. Eine schnellere Erstellung von Berichten ist nur dann nützlich, wenn die Verantwortlichen die enthaltenen Nachweise verstehen und damit eine belastbare Entscheidung treffen können.

Nutzenhypothese	Messung im Pilot
Weniger manuelle Zusammenstellung	Zeitaufwand für ein vergleichbares Nachweispaket
Weniger Rückfragen	Anzahl und Ursache fachlicher Nachforderungen
Klarere Bearbeitung offener Punkte	Zeit bis zur Zuordnung und Erledigung eines Befunds
Tragfähiger Betrieb	Wöchentlicher Pflegeaufwand und ungeklärte Fehler

Funktionsweise und menschliche Verantwortung

Die Architektur trennt fachliche Vorgaben, deren strukturierte Darstellung, technische Auswertung und zusammengefasste Berichte. So können Verantwortliche die Regelpflege zentral organisieren, während Anwendungsteams ihre eigenen Nachweise erzeugen. Die aktuelle Referenz nutzt GitHub Actions und OPA, einen technischen Regelprüfer. Plattformunabhängigkeit ist ein Architekturziel. Sie bedeutet nicht, dass alle anderen Plattformen bereits gleichwertig im Betrieb erprobt sind. [1, 2]

Ein Anwendungsteam erstellt beispielsweise ein Softwarepaket, eine Liste seiner Komponenten und einen Schwachstellenbericht. Ein versionierter Regelsatz prüft ausgewählte Eigenschaften. Anschließend sammelt das zentrale Repository das Ergebnis ein und schlägt seine Aufnahme über einen Pull Request vor, also einen nachvollziehbaren Änderungsvorschlag. Erst Prüfung und Merge übernehmen diesen Stand in die offizielle Übersicht. [4, 6]

Menschen behalten die Entscheidungsverantwortung: Fachliche Eigentümer geben Regeln frei, Anwendungsteams verantworten die Qualität ihrer Nachweise, und benannte Reviewer beurteilen Änderungen. Risikoakzeptanz und Ausnahmen bleiben gesonderte Governance-Entscheidungen. Ein neues Quelldokument kann als Kandidat erfasst werden, ohne sofort neue Regeln auszulösen. [3, 5]

Die Zuordnung bleibt auch bei Änderungen wichtig. Wird beispielsweise eine Nachweisanforderung verschärft, müssen fachliche Eigentümer entscheiden, welche Anwendungen betroffen sind und ab wann die neue Baseline gelten soll. Die technische Pflege übersetzt diese Entscheidung in Modelle und Prüfungen. Bestehende veröffentlichte Regelsätze und historische Ergebnisse bleiben als nachvollziehbare Referenz erhalten. Anwendungsteams übernehmen eine neue Version bewusst, statt unbemerkt wechselnde Regeln zu konsumieren.

Ebene	Aufgabe
Fachliche Vorgaben	Festlegen, welche Anforderungen gelten und wer sie freigibt
Strukturiertes Modell	Vorgaben mit Kontrollen und erwarteten Nachweisen verbinden
Technische Auswertung	Nachweise gegen einen identifizierbaren Regelsatz prüfen
Berichte und Entscheidungen	Ergebnisse zusammenführen und Maßnahmen zuordnen

Aussagekraft der Nachweise und der Freigaben

Ein positives Prüfergebnis gilt für die tatsächlich ausgewerteten Nachweise, den betrachteten Softwarestand und den gewählten Regelsatz. Es ist keine pauschale Zusicherung, dass ein vollständiges System sicher oder für jeden Einsatz freigegeben ist. Diese Grenze ist für die Nutzung durch die Geschäftsführung entscheidend: Automatisierung erhöht die Wiederholbarkeit ausgewählter Prüfungen, ersetzt aber keine umfassende Risikobeurteilung. [3]

Der fachliche Befund und das Vertrauen in die Eingangsdaten sind getrennte Fragen. Das Framework berücksichtigt dazu unter anderem Herkunft, Integrität, Aktualität und den Bezug zum erzeugenden Lauf. Eine Prüfsumme kann spätere Veränderungen erkennbar machen, beweist aber allein weder die korrekte Herkunft noch die inhaltliche Wahrheit eines Dokuments. Ein formal gültiger Nachweis kann daher weiterhin unzureichend sein. [4, 7]

Im Modus Report-only werden Befunde sichtbar, ohne allein deshalb den Workflow scheitern zu lassen. Technische Fehler können einen Lauf dennoch stoppen. Bei einem verbindlichen Modus können relevante Befunde den Workflow fehlschlagen lassen. Ob damit tatsächlich eine Zusammenführung verhindert wird, hängt zusätzlich von den Schutzregeln der jeweiligen Anwendung ab. Neue Piloten wählen Report-only ausdrücklich für alle Auslöser. [5]

Die zentrale Reifeprüfung verlangt für neues Blocking mehr als mehrere grüne Läufe: Dazu gehören geeignete aktuelle Nachweise, Herkunftsprüfung, eine ausreichende Beobachtung, geregelte Ausnahmen, ein Rücknahmeweg und eine verantwortliche Freigabe. Die zuletzt gespeicherte Bewertung erfüllt diese Voraussetzungen für keine der drei erfassten Integrationen. Das ist eine datierte Bewertung, keine laufende Zusicherung. [7]

Bei ha-CPsWMS besteht bereits ein älterer Blocking-Modus, den das Repository als zeitlich begrenztes Bestandsrisiko führt. Die Überprüfung ist bis zum 12. Dezember 2026 vorgesehen. Daraus entsteht keine Freigabe für neue verbindliche Prüfungen. [12]

Für Führungskräfte empfiehlt sich deshalb eine getrennte Betrachtung: Ist der technische Ablauf erfolgreich? Welche fachlichen Befunde sind enthalten? Und reichen Qualität sowie Aktualität der Nachweise für die konkrete Entscheidung aus? Ein grüner Ausführungsstatus kann mit offenem Handlungsbedarf zusammenfallen. Fehlende Beobachtungsmöglichkeiten müssen sichtbar bleiben, damit eine unvollständige Datenlage nicht als erfolgreicher Nachweis erscheint. [9]

Belegter Stand und verbleibende Nachweislücken

Der betrachtete Stand enthält veröffentlichte Regelsätze für DevSecOps L1 und Architektur L1, eine Aufnahme zentraler Ergebnisse, geschützte Änderungsabläufe sowie eine statische Statusanzeige. Ein täglicher Betriebsbericht beobachtet zusätzlich Ausführungen, veraltete Nachweise, die Prüfwarteschlange und die Sicherheitseinstellungen des zentralen Repositories. Die vier Hauptworkflows am betrachteten main-Commit haben erfolgreich abgeschlossen. [5, 8, 9, 13–16]

Die gespeicherten Referenzläufe von ha-CPsWMS stammen vom 15. Juli 2026. Damals bestanden 16 von 16 DevSecOps-Kontrollen und vier von vier Architekturgates. Die Laufnummern 29415015878 und 29415015294 machen diese Aussage überprüfbar. Die Ergebnisse belegen die Integration zum damaligen Zeitpunkt. Sie belegen keine aktuelle Bewertung der Anwendung im September. [8]

Die aktuelle Bereitschaft für einen breiten Produktivbetrieb ist damit nicht nachgewiesen. Unter anderem fehlen eine längere Beobachtung unter realer Last, bestätigte individuelle Zuständigkeiten für den ausgewählten Pilot und eine vollständig erprobte Wiederherstellung der Betriebsumgebung. Vorhandene Anleitungen sind eine Voraussetzung für Betrieb, aber noch kein Nachweis ihrer zuverlässigen Ausführung. [5, 10, 11]

Die zentrale Plattform prüft sich zusätzlich selbst. Dazu gehören die Validierung ihrer Modelle und Regeln sowie Sicherheits- und Dokumentationsworkflows. Diese Kontrollen begrenzen Fehler in der Governance-Infrastruktur. Sie ersetzen weder eine unabhängige Sicherheitsbegutachtung noch einen Nachweis über die vollständige Einhaltung externer Anforderungen. Auch ein erfolgreicher Betriebsbericht kann weiterhin offene Befunde oder nicht einsehbare Einstellungen enthalten. [9]

Bereich	Belegt	Offen für den Pilot
Regeln und Auswertung	Versionierte Baselines und automatisierte Prüfungen	Eignung für die ausgewählten Anwendungen
Ergebnisfluss	Sammlung, Review und zentrale Anzeige	Aktuelle reale Anwendungsergebnisse
Betrieb	Täglicher Bericht und sichtbare Informationslücken	Verlässliche tägliche Bearbeitung durch benannte Personen
Wiederherstellung	Anleitung und lokale Git-Wiederherstellungsprobe	Externe Sicherung, Zugänge und vollständiger Wiederanlauf

Einführung als kontrollierter Testbetrieb

Als Ausgangspunkt bietet sich ein zweiwöchiger Pilot mit ein bis zwei repräsentativen, nicht releasekritischen Anwendungen an. Diese Größe begrenzt das Risiko und hält Rückmeldungen überschaubar. Die konkrete Laufzeit beginnt erst nach Vorbereitung von Zugängen, Verantwortlichkeiten und Nachweisen. Zusätzliche Kapazität für die Vorbereitung muss das Unternehmen vorab einplanen. [5]

Vor Beginn benennt die Geschäftsführung einen Sponsor und die Organisation die operative Verantwortung. Benötigt werden ein zentraler Betriebsverantwortlicher mit Stellvertretung, je Anwendung ein Eigentümer sowie die fachlich zuständigen Reviewer. Für Änderungen des zentralen Maintainers muss eine unabhängige Freigabe erreichbar sein. Bestehende Rollen allein ersetzen keine namentliche Besetzung.

In der ersten Woche verbindet das Team die Anwendungen mit den veröffentlichten Regelsätzen und erzeugt echte aktuelle Nachweise. Es prüft den vollständigen Weg bis zur akzeptierten zentralen Anzeige. In der zweiten Woche beobachtet es Wiederholungen, Fehlerbehandlung, veraltete Nachweise und Wiederherstellung. Gezielte Fehlerfälle gehören in einen vereinbarten isolierten Testkontext. Der Pilot bleibt Report-only. [5, 6]

Zum Abschluss erhält die Geschäftsführung ein kurzes Ergebnisprotokoll. Es enthält beobachteten Nutzen und Aufwand, offene Risiken, konkrete Eigentümer und eine Empfehlung. Mögliche Entscheidungen sind Fortsetzung im begrenzten Umfang, Nacharbeit oder Beendigung. Eine Freigabe des Piloten ist keine automatische Zustimmung zu verbindlichen Lieferstopps.

Der Pilot sollte unterbrochen werden, wenn Ergebnisse verloren gehen, einer falschen Anwendung zugeordnet werden oder Fehler unsichtbar bleiben. Gleiches gilt, wenn notwendige Zugänge oder Reviews dauerhaft fehlen. Das Team hält den Befund fest, benennt die Ursache und entscheidet über die Fortsetzung nach der Korrektur. Eine solche Unterbrechung ist ein verwertbares Ergebnis der Erprobung und darf nicht durch das Entfernen problematischer Nachweise verdeckt werden. [5]

Abnahmepunkt	Erwarteter Nachweis
Vollständiger Ergebnisweg	Neuer Anwendungslauf, Review und korrekte zentrale Zuordnung
Sichtbare Fehler	Fehlende Daten oder Zugriffsprobleme ohne falsches Erfolgssignal
Wiederholbarkeit	Erneute Sammlung erhält vorhandene historische Nachweise
Betriebliche Übernahme	Benannte Zuständigkeiten, Sicherungsprobe und Maßnahmenliste

Betriebsaufwand und Entscheidung über die Ausweitung

Der gegenwärtige Ansatz benötigt für den Pilot keine zusätzliche Datenbank. Strukturierte Ergebnisse liegen versioniert in Git, während große Originalartefakte in den jeweiligen Artefaktspeichern verbleiben. Die Statusanzeige entsteht daraus als abgeleitete Sicht. Ein späterer Wechsel der Speicherung sollte von Suchbedarf, Datenvolumen, Aufbewahrung und gemessenem Aufwand abhängen. [2, 5]

Der wesentliche Aufwand entsteht zunächst durch die Integration der Anwendungen und durch menschliche Bearbeitung: Nachweisqualität verbessern, Zugänge pflegen, Änderungsvorschläge prüfen und offene Befunde zuordnen. Dazu kommen Sicherung, Wiederherstellung und Abwesenheitsvertretung. Die Geschäftsführung sollte diese Arbeit ausdrücklich einplanen. Eine belastbare Budgetschätzung erfordert Angaben zu Anwendungen, Plattformen, bestehenden Werkzeugen und verfügbaren Personen. [5, 10, 11]

Der Betriebsbericht läuft täglich um 06:43 UTC. Er zeigt Handlungsbedarf und fehlende Beobachtungsmöglichkeiten. Er versendet selbst keine Warnmeldungen und eröffnet keine Aufgaben. Jemand muss deshalb auch bemerken, wenn der Bericht ausbleibt. Beispielhafte Warnschwellen wie 30 Tage für Anwendungsevidence oder 24 Stunden für die PR-Warteschlange dienen der Erprobung und sind keine zugesicherten Service-Level. [9]

Eine Ausweitung ist sinnvoll, wenn der Pilot über wiederholte reale Läufe zuverlässige Ergebnisse und vertretbaren Aufwand zeigt. Vor einer unternehmensweiten Einführung sind außerdem Skalierung, Plattformabdeckung, Aufbewahrung und Wiederanlauf zu beurteilen. Verbindliche Prüfungen folgen erst nach der dafür vorgesehenen Reifeprüfung und Freigabe. Diese Schritte lassen sich getrennt entscheiden. [5, 7]

Die vorgeschlagene Entscheidung lautet daher: Den begrenzten Pilot mit benannten Eigentümern und vorher vereinbarter Kapazität vorbereiten. Am Ende über Fortsetzung anhand dokumentierter Ergebnisse entscheiden. Einen unternehmensweiten Rollout oder einen wirtschaftlichen Vorteil bereits heute zuzusichern, würde über die vorhandenen Belege hinausgehen.

Für die Investitionsentscheidung sollte der Abschlussbericht zwischen einmaliger Einführung und wiederkehrendem Aufwand unterscheiden. Wiederverwendbare Regeln können die nächste Integration erleichtern. Unterschiedliche Anwendungslandschaften können zugleich neue Adapter und zusätzliche Nachweise erfordern. Erst die Kombination aus beobachtetem Nutzen, laufendem Aufwand und verbleibenden Risiken begründet die nächste Ausbaustufe. Das schützt davor, aus einem gelungenen Demonstrationslauf vorschnell ein vollständiges Betriebsmodell abzuleiten.

Begriffe und Quellen

Diese Ausgabe ist eine abgeleitete Veröffentlichung für die Geschäftsführung. Sie ändert keine fachlichen Vorgaben und erteilt keine Betriebs-, Risiko- oder Budgetfreigabe. Quellen beziehen sich auf den festgehaltenen Repository-Stand. Ergebnisse vom Juli bleiben als historische Nachweise gekennzeichnet.

Begriff	Bedeutung
Baseline	Versionierter Regelsatz mit definierten Prüfungen und Nachweiserwartungen
Evidence	Nachweise, etwa Komponentenlisten, Scanberichte und Kontextdaten
Pull Request oder PR	Änderungsvorschlag, den berechtigte Personen prüfen und zusammenführen
Report-only	Befunde werden berichtet, ohne allein deshalb den Workflow scheitern zu lassen
Blocking	Relevante Befunde können den Workflow und bei entsprechender Bindung die Lieferung stoppen
OPA	Open Policy Agent, hier die technische Ausführung ausgewählter Regeln

Quellen zum festgehaltenen Stand

- [1] [Vision und aktuelle Ausrichtung](#)
- [2] [Architektur und Schnittstellen](#)
- [3] [Architektonische Grundsätze und menschliche Verantwortung](#)
- [4] [Vertrag für Nachweise](#)
- [5] [Betriebshandbuch und Pilotkriterien](#)
- [6] [Ergebnisaufnahme und Statusanzeige](#)
- [7] [Voraussetzungen für verbindliche Prüfungen](#)
- [8] [Stand und datierte Referenznachweise](#)
- [9] [Täglicher Betriebsbericht](#)
- [10] [Sicherung und Wiederherstellung](#)
- [11] [Zugänge und Tokenpflege](#)
- [12] [Umgang mit dem bestehenden Blocking-Risiko](#)
- [13] [Governance CI am betrachteten main-Stand](#)
- [14] [CodeQL am betrachteten main-Stand](#)
- [15] [Dokumentationsveröffentlichung am betrachteten main-Stand](#)
- [16] [Repository-Sicherheitsprüfung am betrachteten main-Stand](#)